

INFORME DE AUDITORÍA DE SEGURIDAD



CIBER
SEGURIDAD

ÍNDICE

- 1. OBJETIVO Y ALCANCE
- 2 .SUMARIO EJECUTIVO
- 3. CLASIFICACIÓN DE VULNERABILIDADES
- 4. VULNERABILIDADES DETECTADAS
- 5. RECOMENDACIONES GENERALES
- 6.-CONCLUSIÓN

OBJETIVO Y ALCANCE

- El objetivo de este análisis es evaluar el estado de seguridad del sistema **Windows Server 2008** identificado en la red interna , con el fin de identificar y clasificar las vulnerabilidades presentes en sus servicios y configuración, y proporcionar recomendaciones para su mitigación.

SUMARIO EJECUTIVO

- Tras el análisis del sistema Windows Server 2008, se han detectado vulnerabilidades de nivel **crítico, alto, medio y bajo**. Se han identificado vulnerabilidades críticas como ejecución remota de código, exposición innecesaria de servicios, y uso de un sistema operativo sin soporte. Estos factores aumentan el riesgo global del entorno evaluado.
- Recomendamos tomar medidas correctivas inmediatas sobre los servicios de red activos y establecer políticas más restrictivas en la red para reducir el riesgo global.

CLASIFICACIÓN DE VULNERABILIDADES

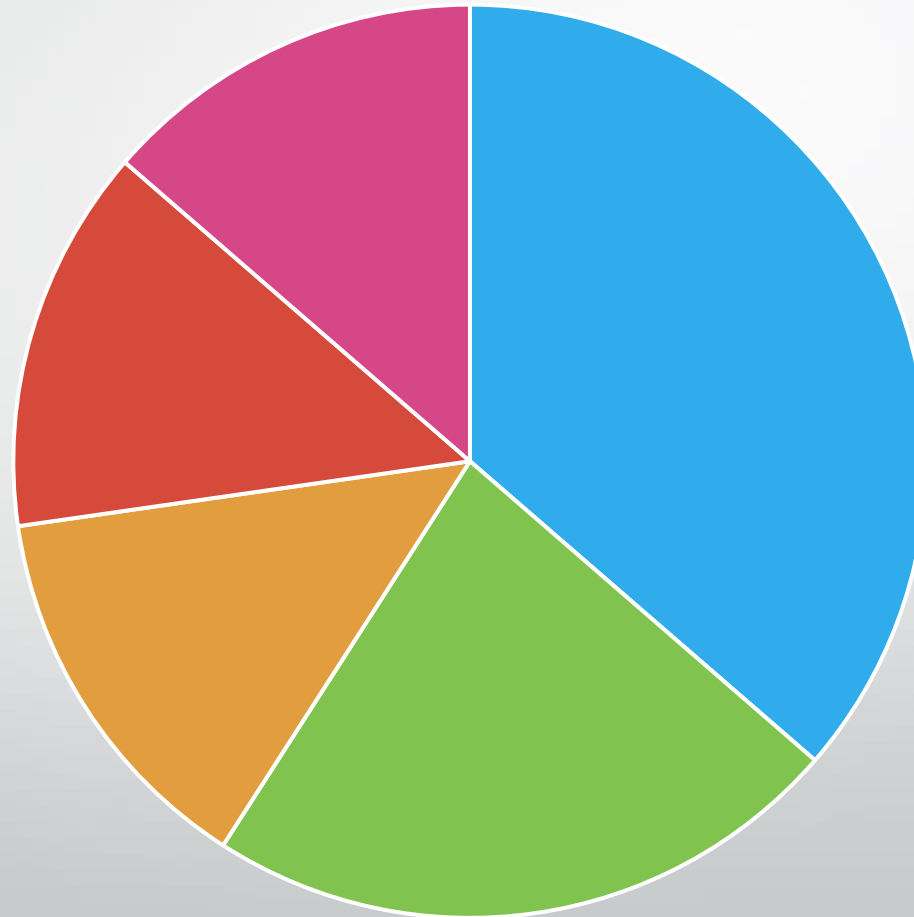
- Las vulnerabilidades se clasifican conforme a los siguientes criterios:
 - **Crítico:** Permite la toma de control total del sistema o ejecución remota de código.
 - **Alto:** Permite acceso a información sensible, credenciales o enumeración de usuarios clave.
 - **Medio:** Expone información técnica no sensible, configuraciones inseguras o servicios innecesarios.
 - **Bajo:** Corresponde a configuraciones por defecto, servicios con información mínima o métodos que, por sí solos, no representan riesgo directo, pero podrían ser aprovechados en combinación con otras debilidades.



Nivel	Puerto	Servicio	Descripción	CVE	Recomendación
Crítico	445	SMBv2	Ejecución remota de código (buffer overflow en srv2.sys).	CVE-2009-3103	Aplicar parches, deshabilitar SMBv1,.Restringir acceso por Firewall
Alto	3389	RDP	Servicio expuesto sin protección (sin NLA), susceptible a fuerza bruta y recolección de credenciales.	CVE-2019-0708 (<i>BlueKeep</i>)	-Habilitar NLA, restringir por IP, MFA y actualización crítica del sistema.
Medio	135, 1688, 49152-49157	MSRPC	-Permite enumeración de red y explotación de servicios Windows como Print Spooler si no está parcheado.	CVE-2021-1675 (<i>PrintNightmare</i>)	-Aplicar parches, segmentar red, mínimo privilegio.
Bajo	139	NetBIOS	Permite la enumeración de usuarios y recursos compartidos desde red local. Útil para reconocimiento en ataques internos.	-	Deshabilitar NetBIOS si no se usa. Filtrar tráfico.
Bajo	-	Sistema Operativo	Uso de sistema sin soporte oficial (Windows Server 2008 R2), lo que implica ausencia de parches frente a nuevas amenazas.	— (<i>riesgo estructural</i>)	Migrar a un sistema con soporte activo (ej. Windows Server 2022).

GRÁFICO DE RIESGOS

Nivel de Riesgo



■ Puerto 445

■ Puerto 3389

■ Puerto 139

■ Sistema Operativo

■ Puertos 135,1688,49152-49157

RECOMENDACIONES

- Se recomiendan medidas correctivas a nivel de servicios, usuarios y red, tales como:
 - Migrar a sistema operativo con soporte oficial.
 - Deshabilitar NetBIOS si no es necesario.
 - Restringir acceso a RDP y MSRPC.
 - Deshabilitar puertos no utilizados.

CONCLUSIÓN

- El sistema evaluado presenta vulnerabilidades de riesgo crítico como la ejecución remota de código mediante SMBv2, combinadas con exposiciones innecesarias de servicios como RDP y NetBIOS, y la utilización de un sistema sin soporte oficial. Esta combinación amplía la superficie de ataque y expone a la organización a posibles incidentes de seguridad.
- Se recomienda priorizar la corrección de estos problemas, actualizar el sistema operativo, aplicar segmentación de red y realizar auditorías periódicas para asegurar la evolución continua de la postura de seguridad.

RECOMENDACIONES TÉCNICAS

- **Segmentación de Red y Reglas de Firewall:**
 - Implementar reglas estrictas de firewall para restringir el acceso a los puertos 135 y 445 solo a los hosts autorizados y necesarios dentro de la red.
 - Considerar la segmentación de la red para aislar sistemas críticos y limitar el movimiento lateral en caso de una brecha.
- **Detección de Intrusiones:**
 - Implementar o fortalecer sistemas de detección de intrusiones (IDS/IPS) que puedan alertar sobre intentos de explotación o actividades anómalas.
- **Auditorías Periódicas:**
 - Realizar pruebas de penetración y auditorías de seguridad de forma regular para identificar nuevas vulnerabilidades y asegurar la efectividad de las medidas de seguridad implementadas.